

Fictotech CISO Incident Report: Hybrid Identity and Cloud Compromise

Verdict: True Positive - High Severity

Prepared for the CISO. Vectra evidence shows an incident that began with command-and-control activity on a datacenter collaboration server, moved laterally to a jump station using adam_admin, and then expanded into M365, Entra ID, Azure, and AWS through adam_admin@fictotech.com.

Report Date	2026-05-19	Observed Incident Window	2026-05-15 13:23:01Z - 19:21:32Z
Primary Account	adam_admin@fictotech.com (Vectra account 3232)	Primary Hosts	marketing-collab-server0; jump-station5

Executive Summary

The incident should be treated as a confirmed high-severity hybrid compromise. Vectra detected C2-like HTTPS tunneling from marketing-collab-server0, internal SMB/LDAP reconnaissance, remote service execution into jump-station5, repeated C2-like tunneling from the jump station, further lateral movement, privileged share access, and then a cloud-control-plane sequence using adam_admin@fictotech.com.

The cloud activity included suspicious sign-ons, automated scripting across Azure and M365, suspicious Copilot access, OAuth consent to Thunder Jaw Backdoor, mailbox-rule persistence, AWS organization/IAM enumeration, AWS access-key creation for another admin user, Azure Key Vault privilege assignment, storage/key-vault secret access, and Azure diagnostic logging disablement.

Overall Severity	Critical	Primary Account Urgency	100
Host Threat / Certainty	100 / 89	Disposition	Immediate IR escalation

Business impact assessment: Potential exposure of cloud secrets and storage keys, persistent access through OAuth/mailbox rules/AWS access keys, impaired Azure diagnostic logging, and lateral movement from datacenter systems. No containment or state-changing action was taken by this assistant.

Scope and Evidence Sources

Source	Evidence Used	Scope
Vectra entity details	Account 3232 plus hosts 94121 and 94124, including urgency, scores, tags, assignments, and sensor context.	Active Vectra entities refreshed during the investigation on 2026-05-19.
Vectra detection details	Detections 17148, 17176, 17180, 17186, 17194, 17203, 17204, 17209, and 17210-17225.	Active detections associated with marketing-collab-server0, jump-station5, and adam_admin@fictotech.com.
Vectra network metadata	Hidden tunnel destinations, destination domain, session counts, byte counts, JA3 and JA3S values exposed in detection evidence.	Network detections on marketing-collab-server0 and jump-station5.
VirusTotal enrichment	Public IP reputation checks for 34.216.204.23, 66.172.48.228, 74.201.86.232, and 40.121.154.127.	IOC corroboration only; reputation does not override Vectra behavioral detections.

Incident Timeline

Time (UTC)	Activity	Evidence and Interpretation
2026-05-15 13:23:01 - 13:33:22	Initial C2-like HTTPS tunnel	marketing-collab-server0 communicated with 40.121.154.127 / minutemen.vault-tech.org. Vectra classified this as Hidden HTTPS Tunnel, with 118 sessions, 29,218 bytes sent, and 649,650 bytes received. Detection 17148.
2026-05-15 14:50:24 - 14:56:17	SMB network sweep	marketing-collab-server0 performed 196 TCP/445 attempts across 10.232.100.0/24 with no successes, consistent with internal discovery. Detection 17176.

Time (UTC)	Activity	Evidence and Interpretation
2026-05-15 15:31:45	LDAP account enumeration	marketing-collab-server0 queried DC-ficto01 / 10.232.100.32 for user and account objects, returning 65 objects. Detection 17180.
2026-05-15 16:05:14	Remote service execution to jump station	marketing-collab-server0 used adam_admin to invoke CreateServiceW and StartServiceW against jump-station5 / 10.232.100.150 through svcctl. Detection 17186.
2026-05-15 16:05:26 - 16:16:17	C2-like tunnel on jump station	jump-station5 communicated with the same external destination, 40.121.154.127 / minutemen.vault-tech.org. Hidden HTTPS Tunnel, 124 sessions, 29,690 bytes sent, 656,718 bytes received. Detection 17194.
2026-05-15 17:42:23	Remote service execution from jump station	jump-station5 used adam_admin to invoke CreateServiceW and StartServiceW against IP-10.232.100.30 / 10.232.100.30. Detection 17203.
2026-05-15 17:42:39 - 17:43:20	Internal port scan	jump-station5 scanned 10.254.100.62 with 1,000 attempts and no successes. Detection 17204.
2026-05-15 18:18:59	High-privilege share access	adam_admin accessed cifs:NetworkandCloudArchitectureShare from jump-station5. Vectra marked the resource privilege as High while the account was normally lower privilege. Detections 17209 and 17210.
2026-05-15 18:32:16 - 19:21:28	Automated cloud and M365 access	adam_admin@fictotech.com used scripting/tooling across Azure AD, ARM, Key Vault, SharePoint, Microsoft Graph, Exchange Online, and Teams from 34.216.204.23 and 66.172.48.228. Detection 17213.
2026-05-15 18:35:30 - 19:21:28	Suspicious Entra sign-ons	Sign-ons from 34.216.204.23, 66.172.48.228, and 74.201.86.232 carried rare OS/location/anonymization signals and mixed MFA outcomes. Detection 17211.
2026-05-15 18:37:56	Suspicious Copilot access	CopilotInteraction by adam_admin@fictotech.com from 74.201.86.232. Detection 17212.
2026-05-15 18:43:03	Suspicious OAuth consent	OAuth application Thunder Jaw Backdoor observed with Mail.Read, User.Read, offline_access, openid, and profile scopes. Detection 17215.
2026-05-15 18:58:47	Mailbox-rule persistence	Inbox rule fictotech_secrets_adam_admin@fictotech.com was created from 66.172.48.228 with DeleteMessage=True. Detection 17217.
2026-05-15 19:13:47 - 19:13:48	AWS organization discovery	SAML:adam_admin@fictotech.com assumed AAD_VTL_AdministratorAccess and ran DescribeOrganization/ListAccountAliases in AWS account 073942728427 from 34.216.204.23. Detection 17221.
2026-05-15 19:14:51 - 19:17:13	AWS IAM enumeration	The same assumed role ran ListUsers, ListRoles, and ListGroups through Boto3/Botocore user agents. Detection 17219.
2026-05-15 19:18:14	AWS access-key creation	AWS CreateAccessKey was performed for another admin user, alex_admin@fictotech.com-191512. Detection 17222. Access-key material is intentionally not reproduced.
2026-05-15 19:20:23 - 19:21:32	Azure access from AWS-hosted source	Activity from 34.216.204.23 included role assignment, storage account key listing, diagnostic setting deletion, Key Vault secret listing, and vault access. Detection 17224.
2026-05-15 19:20:24	Key Vault privilege grant	adam_admin@fictotech.com was granted Key Vault Administrator on fic-secret-vault. Detection 17225.
2026-05-15 19:21:28 - 19:21:32	Credential and secret access	Suspicious Azure credential access touched storage accounts and Key Vault resources, including storage/key-vault providers and two credential-access indicators. Detection 17223.
2026-05-15 19:21:30	Diagnostic logging disabled	Azure diagnostic logging was disabled for customer3197datastore / customer-storage-diag-setting-2 in resource group fictotech_azure. Detection 17220.

Connected Entities and Assets

Entity	Role in Incident	Observed State / Notes
adam_admin@fictotech.com Vectra account 3232	Primary compromised identity used across Kerberos, O365, AWS, and Entra principal surfaces.	Critical, urgency 100, threat 100, certainty 79, active, prioritized, unassigned, tag Fictotech.
Associated account identities	Identity aliases observed for the same user across services.	adam_admin@fictotech.com; O365:adam_admin@fictotech.com; SAML:adam_admin@fictotech.com; 528f98b1-f6e1-4e9b-a2e7-539457bdf00c.
marketing-collab-server0 / 10.232.100.62 Vectra host 94121	Earliest observed affected host: C2-like tunnel, SMB sweep, LDAP enumeration, then remote execution into jump-station5.	Critical, threat 100, certainty 83, datacenter group. Notes previously indicated EDR limitations and escalation to L2.
jump-station5 / 10.232.100.150 Vectra host 94124	Lateral-movement target and follow-on launch point for C2-like traffic, remote execution, scanning, and privileged CIFS access.	Critical, threat 100, certainty 89, active, unassigned, datacenter group.
DC-ficto01 / 10.232.100.32 Vectra host 94119	LDAP enumeration target from marketing-collab-server0.	Connected infrastructure asset; query returned 65 account/user objects.
IP-10.232.100.30 / 10.232.100.30 Vectra host 94287	Remote service execution target from jump-station5 using adam_admin.	Connected internal host; no separate active detection set cited in this report.
10.254.100.62	Internal port-scan target from jump-station5.	1,000 attempts, no successes observed in Vectra detection evidence.
NetworkandCloudArchitectureShare	High-privilege CIFS share accessed by adam_admin from jump-station5.	Resource privilege marked High by Vectra.
AWS account 073942728427	AWS discovery, IAM enumeration, and access-key creation via federated adam_admin role.	Assumed role path: SAML:adam_admin@fictotech.com to AAD_VTL_AdministratorAccess.
Azure tenant and subscription	Key Vault privilege grant, diagnostic logging disablement, credential/secret access.	Tenant 9ccb96dd-ebcf-44ff-badd-5a02728f9ef1; subscription 5be05d3a-316e-4454-a684-bd0f69f7ec64; resource group fictotech_azure.
fic-secret-vault	Azure Key Vault affected by privilege grant and vault/secret access activity.	Key Vault Administrator granted to adam_admin@fictotech.com during incident window.
customer3197datastore	Azure storage/logging target where diagnostic logging was disabled.	Diagnostic setting customer-storage-diag-setting-2 disabled at 19:21:30Z.
Thunder Jaw Backdoor	Suspicious OAuth application observed for adam_admin@fictotech.com.	Scopes included Mail.Read, User.Read, offline_access, openid, and profile.
fictotech_secrets_adam_admin@fictotech.com	Suspicious mailbox rule created in M365.	Rule action included DeleteMessage=True.

External Infrastructure and IOC Context

Observable	Incident Context	Assessment
40.121.154.127 minutemen.vault-tech.org	Destination for Hidden HTTPS Tunnel detections from marketing-collab-server0 and jump-station5. Shared JA3 3b5074b1b5d032e5620f69f9f700ff0e and JA3S ec74a5c51106f0419184d0dd08fb05bc.	Behavioral C2 indicator. VirusTotal returned 0 malicious and 0 suspicious detections; this does not reduce Vectra behavioral confidence.
34.216.204.23	Source IP for AWS and Azure activity: AWS enumeration, access-key creation, Azure role assignment, storage key listing, Key Vault access, and diagnostic setting deletion.	High-risk cloud source in incident context. VirusTotal returned 0 malicious and 0 suspicious detections; ASN 16509, US.
66.172.48.228	Source IP for M365 mailbox-rule creation and Entra scripting activity.	Suspicious in behavioral context. VirusTotal returned 0 malicious and 0 suspicious detections; ASN 4213, US.
74.201.86.232	Source IP for suspicious Copilot access and Entra sign-on evidence.	Suspicious in behavioral context. VirusTotal returned 0 malicious and 0 suspicious detections; ASN 12182, US.

Likely Attack Narrative

The most defensible interpretation is a multi-stage intrusion. An operator established or used an HTTPS tunnel from marketing-collab-server0, performed SMB and LDAP discovery, then used adam_admin to execute services on jump-station5. The same external tunnel pattern appeared on jump-station5 shortly afterward, followed by remote execution to another internal host, scanning, and anomalous high-privilege share access. The identity then became active across SaaS and cloud control planes, showing automation, OAuth and mailbox persistence, AWS discovery and key creation, Azure privilege changes, secret access, and logging impairment.

The density and order of events, the cross-domain nature of the activity, and the use of multiple external source IPs make benign administration unlikely. The incident should be handled as an active or recently active compromise until containment and forensic validation are complete.

Risk and Impact

Risk Area	Impact	Evidence
Credential and secret exposure	Potential compromise of storage keys, Key Vault secrets, and cloud credentials.	Azure Suspect Credential Dump, Azure Suspicious Access from AWS Cloud, Key Vault Administrator grant.
Persistence	Potential durable access through OAuth refresh tokens, mailbox rules, and AWS access keys.	Thunder Jaw Backdoor OAuth app, M365 DeleteMessage inbox rule, AWS CreateAccessKey.
Defense evasion	Reduced Azure visibility during or after the incident.	Azure diagnostic logging disabled on customer3197datastore.
Lateral movement	Remote service execution and internal discovery from datacenter systems.	Remote execution from marketing-collab-server0 to jump-station5, remote execution from jump-station5 to 10.232.100.30, SMB/LDAP recon, and port scan.
Cloud control-plane exposure	Potential unauthorized access to AWS IAM, Azure Key Vault, Azure storage keys, and M365 mailbox data.	AWS IAM enumeration, Azure storage listkeys, Key Vault operations, Mail.Read OAuth scope, suspicious Copilot access.

Recommended Executive Actions

- 1 Declare or continue formal incident response handling and assign accountable owners for identity, endpoint, cloud, and communications workstreams.
- 2 Preserve Vectra evidence, EDR telemetry, Entra ID sign-in/audit logs, M365 unified audit logs, AWS CloudTrail, Azure Activity Logs, Key Vault logs, and storage account logs before disruptive containment where possible.
- 3 With human approval, contain adam_admin@fictotech.com: revoke sessions and refresh tokens, rotate credentials, review MFA methods, and disable or restrict the account until forensic review completes.
- 4 Remove or disable the suspicious OAuth application and mailbox rule after preserving evidence; search for the same app, scopes, and rule pattern across other users.
- 5 Rotate exposed or potentially exposed AWS access keys, Azure storage account keys, Key Vault secrets, certificates, and service principal credentials touched during the incident window.
- 6 Investigate marketing-collab-server0 and jump-station5 with EDR and forensic tooling, focusing on 2026-05-15 13:20Z-18:30Z, service creation, outbound HTTPS to 40.121.154.127, and lateral movement artifacts.
- 7 Review AWS account 073942728427 for persistence, unauthorized keys, role changes, new users, CloudTrail tampering, and data access following 19:13Z.
- 8 Restore and validate Azure diagnostic logging on affected resources, then run a retrospective search for activity during the visibility gap.

Known Gaps

- This report is based on Vectra entity and detection evidence plus prior IOC enrichment; it is not a full endpoint forensic image, SIEM reconstruction, or legal evidence package.

- No raw Investigation Query SQL event timeline was executed for this report-generation step; detections provide the authoritative Vectra event anchors cited here.
- No direct EDR process tree, memory analysis, file-system artifact review, mailbox-content review, or cloud object-access validation was performed by this assistant.
- Vectra behavior and metadata do not prove exact data exfiltration volume from cloud stores; cloud-native logs and storage/key-vault audit records are required for that determination.
- No containment, note updates, alert closure, entity assignment, account disablement, session revocation, or ticket creation was performed by this assistant.

Conclusion

The evidence supports a confirmed, high-severity compromise spanning on-premises lateral movement and cloud identity/control-plane abuse. The priority is to preserve evidence, contain the compromised identity and affected hosts with approval, remove persistence, rotate exposed secrets, and validate whether cloud data or secrets were accessed or exfiltrated.